trigger initiating this reporting deadline to the moment the service provider "has a reasonable basis to conclude that a notifiable incident has occurred or is occurring."[252]

Other commenters suggested narrowing the scope of incidents that would trigger required notice by service providers to a covered institution.[253] One commenter asserted that incident response program requirements should only address and be triggered by incidents that involve unauthorized access to or use of a subset of customer information (e.g., *sensitive* customer information).[254] Another commenter stated that the proposal would result in notices to a covered institution if there has been unauthorized access to the service provider's customer information system, regardless of whether the covered institution's customers were in any way affected by the breach.[255] Instead, the commenter stated that the Commission should limit the scope of incidents requiring notification to a covered institution to only those resulting in unauthorized access to that covered institution's "customer information" maintained by the service provider.[256]

After consideration, the Commission is extending the deadline for providing notification from 48 to 72 hours. Although we appreciate that the 48-hour standard in the proposed amendments may not be an uncommon arrangement between covered institutions and their service providers in the market today, extending this deadline by 24 hours will provide service providers with additional time to conduct more effective investigations of a breach at the service provider, resulting in more relevant and accurate notifications to the covered institution. Further, the 72-hour standard brings this notification deadline in alignment with other existing regulatory

---

252 *See* Microsoft Comment Letter.

253 *See* Schulte Comment Letter; SIFMA Comment Letter 2.

254 *See* Schulte Comment Letter.

255 *See* SIFMA Comment Letter 2.

256 *See id.*

standards, which should reduce costs to service providers and covered institutions without sacrificing the investor protection benefits of the rule.[257]

The Commission disagrees that there should be no specified notification deadline and that covered institutions and service providers should be able to negotiate the appropriate timing for such notification. As discussed above, upon receipt of the breach notification from the service provider, a covered institution must initiate its incident response program adopted pursuant to paragraph (a)(3) of the final amendments.[258] As covered institutions cannot reasonably be expected to initiate their incident response programs for incidents occurring at a service provider that the covered institution is not yet aware have occurred, providing the indefinite timeline commenters suggest could significantly hinder the effectiveness of covered institutions' incident response programs.[259] For example, delays in the service provider's notification to the covered institution of a breach could result in further delays in the initiation of the incident containment and control procedures the covered institution has adopted pursuant to its incident response program obligations, consequently diminishing their effectiveness. Further, any excess delay in the service provider's notification to the covered institution and resulting delay in the covered

---

257 As discussed above, a 72-hour reporting deadline aligns with, among others, requirements in CIRCIA that include a 72-hour deadline for entities to report cyber incidents to CISA, Executive Order 14028 on "Improving the Nation's Cybersecurity," which directs the Federal government to incorporate a 72-hour reporting period into the FAR, the DFARS, NYDFS's cybersecurity regulations, which include a 72-hour reporting deadline to NYDFS after any determination that a cybersecurity incident has occurred at the covered entity, its affiliates, or a third-party service provider, the European Union's GDPR, as well as the European Union's NIS 2 Directive. *See* discussion of Microsoft Comment Letter and cited regulatory frameworks *supra* footnote 245.

258 *See supra* footnote 237 and accompanying discussion.

259 While a covered institution's receipt of such notice from a service provider establishes such awareness, as discussed above, where a covered institution has otherwise independently detected an incident of the unauthorized access to or use of customer information at the service provider, it must implement its incident response program under paragraph (a)(3) of the final amendments regardless of any notice provided by the service provider. *See supra* footnote 237 and accompanying discussion. *See also* final rule 248.30(a)(3).

institution's initiation of its incident response program, could significantly hinder the goal of the final amendments of providing customers with timely notification of data breaches so that they may take remedial action. In light of this, reasonably designed policies and procedures generally should also account for instances where the covered institution determines that a service provider has failed to provide notice to the covered institution within 72 hours as required. In such circumstances, in addition to initiating its incident response program upon receipt of the notice as required, a covered institution generally should reevaluate its policies and procedures governing its relationship with the service provider and make adjustments as necessary to ensure the service provider will take the required appropriate measures going forward.

Further, the Commission is adopting as proposed the "becoming aware of" standard for triggering a service provider's breach notifications to a covered institution. This standard is intended to enable the covered institution to implement its incident response program expeditiously. While the Commission believes it is appropriate, as discussed above, to extend the timeframe for service provider notifications from 48 to 72 hours, adopting either a "having a reasonable basis to conclude" standard or a "determining" standard could frustrate the investor protection goals of these final amendments. Specifically, adopting either of these alternative standards could result in undue delays in a service provider's notification to the covered institution beyond the point at which the service provider is already aware that a relevant breach has occurred. Such a delay would frustrate the goal of both enabling covered institutions to initiate their incident response program expeditiously, as well as the goal of providing timely notification to affected individuals. For similar reasons, given that the "determining" standard used by Federal banking regulators involves a different context—notice to the banking organization of downgraded or degraded services—adopting it here solely to harmonize

regulatory approaches would be inappropriate.[260] Accordingly, the final amendments maintain the proposed "becoming aware of" standard for triggering a service provider's notification.

The Commission also is not limiting the scope of incidents to be reported to covered institutions to only those involving "sensitive customer information" or alternatively to breaches that result in unauthorized access to "customer information" maintained by the service provider rather than those that result in unauthorized access to a service provider's "customer information system." Under the final amendments, a covered institution's incident response program must be reasonably designed to "detect, respond to, and recover from unauthorized access to or use of customer information," and must include provisions to assess such incidents to "identify the *customer information systems* and *types of customer information* that may have been accessed or used without authorization" and take appropriate steps to "contain and control the incident to prevent further unauthorized access to or use of customer information."[261] As discussed above, in doing so, we are requiring that covered institutions' incident response programs address any incident involving customer information—not merely those involving *sensitive* customer information—and also account for the identification of affected customer information *systems* in addition to the types of customer information that may have been accessed or used without authorization.[262] For the same reasons, we are not limiting the scope of reportable incidents to

---

260 Specifically, the Federal banking agency regulations require notification from the bank service provider to "each affected banking organization customer as soon as possible when the bank service provider determines that it has experienced a computer-security incident that has materially disrupted or degraded, or is reasonably likely to materially disrupt or degrade, covered services provided to the banking organization for four or more hours." *See* 12 CFR 304.24(a).

261 *See* final rule 248.30(a)(3)(i) and (ii). *See also* discussion of the Assessment and Containment and Control portions of covered institutions' incident response program requirements *supra* sections II.A.1 and II.A.2.

262 *See* discussion of incident response program Assessment and Containment and Control requirements, and the reasons for not restricting such requirements to only "sensitive customer information" *supra* Sections II.A.1 and II.A.2. *See also* discussion of incident response program Containment and Control requirements and the reasons for requiring identification of both the customer information systems as well as types of customer information that may have been accessed or used without authorization *supra* Section II.A.2.

only those breaches in security at the service provider that result in unauthorized access to sensitive customer information, or alternatively to only those breaches that result in unauthorized access to "customer information" maintained by the service provider.

c. Delegation of Notice and Covered Institutions' Customer Notification Obligations

The Commission is adopting as proposed language that permits covered institutions, as part of their incident response programs, to enter into a written agreement with their service providers to notify affected individuals on the covered institution's behalf.[263] However, the Commission is also adopting a new paragraph that states that, notwithstanding any covered institution's use of a service provider, the covered institution's obligation to ensure that affected individuals are notified in accordance with this rule rests with the covered institution.[264]

One commenter stated that it is appropriate to permit a covered institution to enter into a written agreement with its service provider to notify affected individuals on the covered institution's behalf, so long as the notification is actually ultimately provided to customers in a manner that satisfies the covered institution's notice obligations.[265] The Commission agrees that there may be situations where a covered institution's service provider is better situated than the covered institution to provide a customer a breach notification. Thus, the Commission is adopting paragraph (a)(5)(ii) as proposed.[266]

---

263 *See* final rule 248.30(a)(5)(ii) (stating "As part of its incident response program, a covered institution may enter into a written agreement with its service provider to notify affected individuals on its behalf in accordance with paragraph (a)(4) of this section."); *see also* proposed rule 248.30(b)(5)(ii).

264 *See* final rule 248.30(a)(5)(iii).

265 *See* Schulte Comment Letter (stating that if the service provider was the victim of a cyber-attack that included unauthorized access to the covered institution's sensitive customer information, the service provider would be better situated to notify the affected customers).

266 As discussed below *infra* footnote 391 and in the accompanying discussion, in accordance with the recordkeeping provisions adopted in these final amendments, covered institutions, other than funding

At the same time, the Commission is adopting a new paragraph (a)(5)(iii) to specify that even where a covered institution uses a service provider, the obligation to ensure that affected individuals are notified in accordance with the rule rests with the covered institution.[267] While the proposing release included similar language,[268] the final rule explicitly provides that the covered institution will be obligated to satisfy the customer notification requirements of paragraph (a)(4) in the event of a relevant breach occurring at the service provider. The Commission agrees that in providing flexibility to covered institutions by permitting them to enter into a written agreement with their service providers to notify affected individuals on the covered institution's behalf, such notification to customers should be provided in a manner that satisfies the covered institution's notice obligations. Accordingly, where a covered institution has entered into a written agreement with its service provider to provide notice on the covered institution's behalf, the covered institution must ensure that the service provider has satisfied the customer notification obligations.[269] To accomplish this, the covered institution's policies and procedures

---

portals, are required to preserve a copy of any notice transmitted by the service provider to any customer on the covered institution's behalf following the covered institution's determination made regarding whether notification is required pursuant to 17 CFR 248.30(a)(4). *See also* discussion of funding portal recordkeeping requirements *infra* footnote 385.

267 *See* final rule 248.30(a)(5)(iii) (specifically stating "Notwithstanding a covered institution's use of a service provider in accordance with paragraphs (a)(5)(i) and (ii), the obligation to ensure that affected individuals are notified in accordance with paragraph (a)(4) of this section rests with the covered institution").

268 In the proposal, the Commission stated that in such a circumstance where the covered institution has delegated performance of its notice obligation to a service provider through written agreement, the covered institution would remain responsible for any failure to provide a notice as required by the proposed rule. *See* Proposing Release at II.A.3. The Commission also stated in the proposal that covered institutions may delegate other functions to service providers, such as reasonable investigation to determine whether sensitive customer information has not been and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience, but covered institutions would remain responsible for these functions even if they are delegated to service providers. *See id.* at footnote 93; *see also* discussion of paragraph (a)(4) customer notification obligations *supra* section II.A.3. Under new paragraph (a)(5)(iii), covered institutions may still delegate such functions to service providers as stated in the proposal, but the rule text expressly states that the ultimate obligation to ensure affected individuals are notified in accordance with paragraph (a)(4) will remain with the covered institution.

269 *See* final rule 248.30(a)(5)(iii); *see also* final rule 248.30(a)(4) (enumerating the scope of the covered institution's customer notification obligations).

should consider including steps for conducting reasonable due diligence to confirm that the service provider has provided notice to affected customers. In addition to maintaining a copy of any notice transmitted to affected individuals by the service provider on the covered institution's behalf as required by the covered institution's (other than funding portals) recordkeeping obligations under the final amendments,[270] effective due diligence might also include obtaining confirmation of delivery of such notification in the form of attestations or certifications made by the service provider. Covered institutions could also consider confirming with a sample of affected customers that they received such service provider notifications.

In addition, where the covered institution has entered into a written agreement with its service provider to provide notice on the covered institution's behalf pursuant to paragraph (a)(5)(ii), and the covered institution determines that the service provider has not provided such notifications in a manner that satisfies the conditions of paragraph (a)(4), the covered institution must still ensure that notification is provided to the customer, and the covered institution's policies and procedures generally should be designed to address these instances. To accomplish this, the covered institution generally should conduct timely due diligence to identify any lack of notification by the service provider to the customer and remedy the matter in advance of the deadline set out in paragraph (a)(4).

d. Service Provider Definition

The Commission is adopting the definition of "service provider" to mean "any person or entity that receives, maintains, processes, or otherwise is permitted access to customer

---

[270] *See, e.g.* final rule 17 CFR 240.17a-4(e)(14)(iii). *See also* discussion on a covered institution's recordkeeping obligations as to notices delivered to customers by its service providers *infra* footnote 391 and accompanying discussion. Funding portals generally should maintain all copies of such notices in connection with their own requirements to demonstrate compliance with Regulation S-P. *See* discussion of existing funding portal recordkeeping obligations *infra* footnote 385.

information through its provision of services directly to a covered institution."[271] This definition thereby includes affiliates of covered institutions if they are permitted access to this information through their provision of services. The scope of this definition is intended to help protect against the risk of harm that may arise from service providers' access to a covered institution's customer information and customer information systems.[272]

A number of commenters addressed the scope of the proposed definition. Several commenters suggested narrowing the scope of the service provider definition by revising it to exclude affiliates or other GLBA regulated entities.[273] Similarly, three commenters asserted that the Commission should revise the definition to exclude affiliates and other entities under common control with the covered institution, as those affiliates are typically subject to the same cybersecurity and privacy programs, including service provider management, which are frequently structured and operate on a group-wide basis.[274] One of these commenters also stated the Commission should also exclude entities subject to the GLBA that have direct contractual relationships with the client.[275] This commenter separately asserted that the service provider definition should be narrowed to only cover those persons or entities that are a third party and receive, maintain, process, or otherwise are permitted access to *sensitive* customer information, so that covered institutions can prioritize "higher-risk service providers" and not expend

---

271 *See* final rule 248.30(d)(10); *see also* proposed rule 248.30(e)(10).

272 For example, in 2015, Division of Examinations staff released observations following the examinations of some institutions' cybersecurity policies and procedures relating to vendors and other business partners, which revealed mixed results with respect to whether the firms had incorporated requirements related to cybersecurity risk into their contracts with vendors and business partners. *See* EXAMS, Cybersecurity Examination Sweep Summary, National Exam Program Risk Alert, Volume IV, Issue 4 (Feb. 3, 2015), at 4, available at https://www.sec.gov/about/offices/ocie/cybersecurity-examination-sweep-summary.pdf.

273 *See*, *e.g.*, CAI Comment Letter; IAA Comment Letter 1; SIFMA Comment Letter 2; and Schulte Comment Letter.

274 *See* CAI Comment Letter; IAA Comment Letter 1, SIFMA Comment Letter 2.

275 *See* IAA Comment Letter 1.

resources unnecessarily on an overly broad set of service providers.[276] Finally, one commenter requested that the Commission "clarify the scope of the service provider definition, including whether service providers would include financial counterparties such as brokers, clearing and settlement firms, and custodial banks."[277]

As stated above, we are modifying the definition of service provider from the proposal to remove reference to third parties in response to commenters to incorporate into rule text the Commission's intended scope of the "service provider' definition, as discussed in the Proposing Release.[278] It would not be appropriate to narrow the definition to exclude affiliates or non-affiliates that are also subject to the GLBA, as commenters have suggested. While a covered institution's affiliates may collectively operate under the same cybersecurity and privacy programs, such uniformity in approach does not diminish the risk of harm to the institution's customers in the event of a cyber incident involving unauthorized access to or use of customer information at the affiliate.[279] This risk is similarly not diminished where a cyber incident involving unauthorized access to or use of customer information occurs at a covered institution's unaffiliated service provider that is subject to the GLBA, even where the service provider has a direct contractual relationship with the client. In such instances, maintaining such an entity's inclusion within the service provider definition will help ensure that the covered institution is

---

276 *See id.*

277 *See* SIFMA Comment Letter 2.

278 *See* Proposing Release at Section II.A.3, stating "This definition would include affiliates of covered institutions if they are permitted access to this information through their provision of services."

279 While we are not narrowing the service provider definition to exclude affiliates of the covered institution, in most instances it generally should be appropriate for the covered institution to rely upon the adherence of any affiliated service provider to enterprise-wide cybersecurity and privacy programs that cover both the covered institution and its affiliates, so long as such programs satisfy the requirements of the final rules and the covered institution does not know, or have reason to know, that the affiliate is not adhering to such enterprise-wide programs.

made aware of cyber incidents that occur at the service provider to aid in both the covered institution's oversight of its service providers, as well as satisfaction of its customer notification and broader customer information safeguarding obligations under the final amendments. It is thus important for the service provider definition to remain sufficiently broad to address these risks by setting out clear obligations for all parties possessing legitimate access to customer information regarding both the safeguarding of that information, and, where necessary, ensuring notification to the affected customers in the event of a breach involving unauthorized access to or use of customer information. However, while we are not narrowing the scope of the "service provider" definition to exclude either affiliates of the covered institution or unaffiliated service providers that are independently subject to the GLBA, pursuant to paragraph (a)(5)(ii) of these final amendments the covered institution and a service provider may enter into a written agreement for the service provider to notify affected individuals on its behalf in in the event of a breach at the service provider, as discussed above. [280]

Further, it would not be appropriate to narrow the service provider definition to only address those persons or entities that operate as "higher-risk service providers" that receive, maintain, process, or are otherwise permitted access to *sensitive* customer information, as one commenter suggested. As discussed above, the scope of information covered by the assessment and containment and control requirements of the final amendments is designed to help ensure all information covered by the requirements in the GLBA is appropriately safeguarded, and that

---

[280] *See* discussion on Delegation of Notice and Covered Institutions' Customer Notification Obligations *supra* Section II.A.4.c. *See also* 17 CFR 248.30(a)(5)(ii). The permissibility of such written agreements between covered institutions and their service providers, including both their affiliates and those unaffiliated service providers that are also subject to the GLBA, may also help reduce costs related to customer notifications at the covered institution, and help reduce the risk of over-notification of affected individuals in instances where both the covered institution and its affiliated service provider are independently subject to customer notification obligations for the same breach in security.